DDoS Tuning Project

Attack Simulation, Detection, Response, and Defense

Objective

The objective of this practical is to demonstrate a clear, end-to-end understanding of Denial of Service (DoS) and Distributed Denial of Service (DDoS) attacks. This includes how such attacks work, how they are launched in a controlled lab environment, how they are detected, and how organizations defend against them using layered security controls such as rate limiting and Web Application Firewalls (WAFs).

This exercise is conducted strictly for educational and defensive security purposes.

Background and Conceptual Understanding

Before touching tools, it’s important to understand what problem a DDoS attack is actually trying to cause.In information security, availability is one of the three pillars of the CIA triad, alongside confidentiality and integrity. A DoS or DDoS attack specifically targets availability. In simple terms, when a user visits a website, their browser sends a request to the server asking for content. The server processes the request and sends a response back. This is normal behavior.

The issue begins when the number of incoming requests exceeds what the server, application, or network can reasonably handle. At that point, legitimate users can no longer access the service. The service is still there, but effectively unavailable.

A DoS attack comes from a single source while DDoS attack comes from multiple distributed sources, often making it harder to block because the traffic appears to be coming from many different locations at once.That distinction matters a lot when it comes to detection and response.

Practical Environment Overview

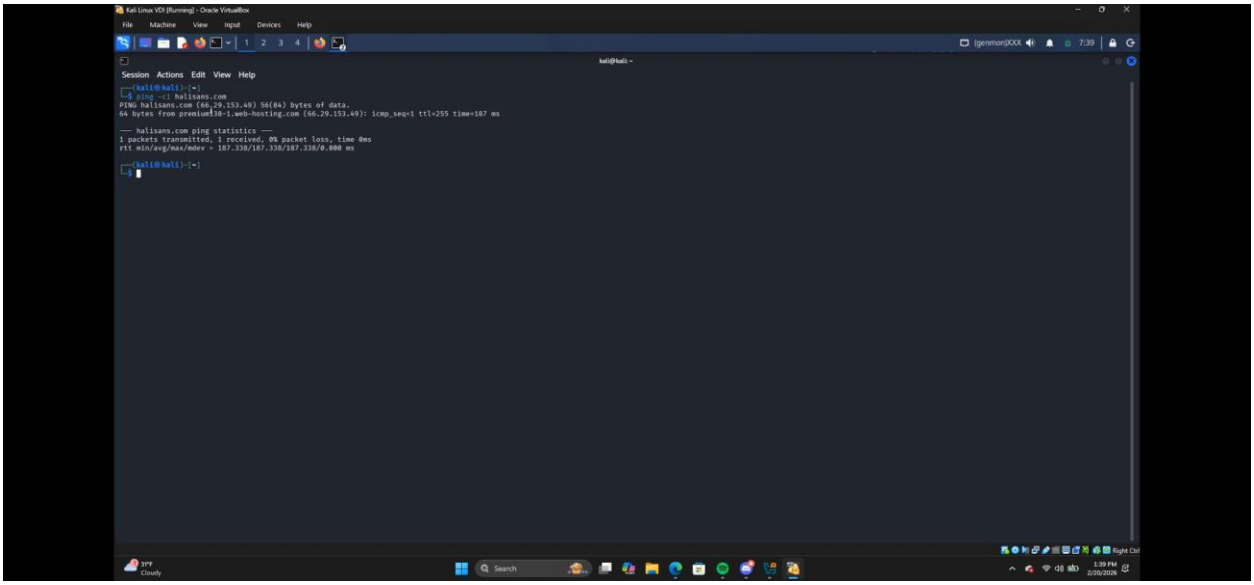
- Operating System: Linux (Kali Linux)
- Target: Test web application with permission
- Network Type: Public-facing web service
- Attack Focus: Application-layer and transport-layer flooding
- Defensive Focus: Rate limiting, WAF behavior, and traffic control

Stage 1: Identifying the Target and Reconnaissance

The first step in any availability-focused test is understanding what is publicly exposed.
I began by identifying the target domain and resolving its IP address using basic network utilities.

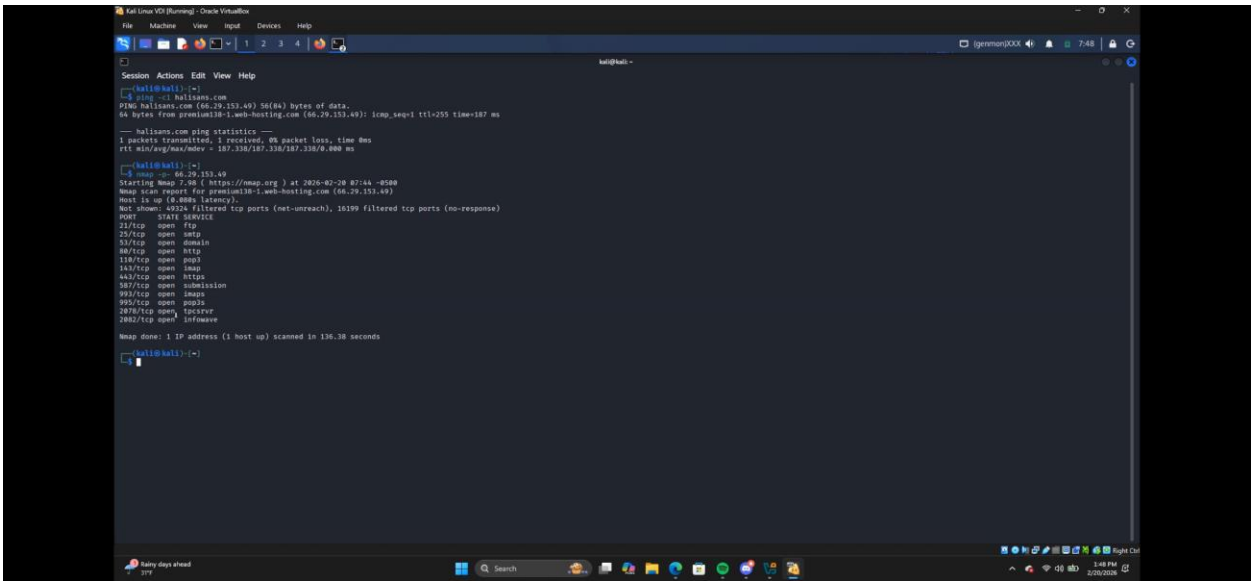
This step helps confirm:

- The server is reachable
- The service is online
- The attack surface is public-facing



Stage 2: Understanding Port Relevance

DoS and DDoS attacks are effective only when they target port is open and active services. For example: Port 80 (HTTP), Port 443 (HTTPS), Port 22 (SSH), Port 21 (FTP) etc depending on the port that is open. Flooding a closed port has no practical effect because no service is listening there. In this practical, HTTPS (port 443) was selected because it represents a real, user-facing service.This mirrors real-world attacks, which almost always target public services customers rely on.



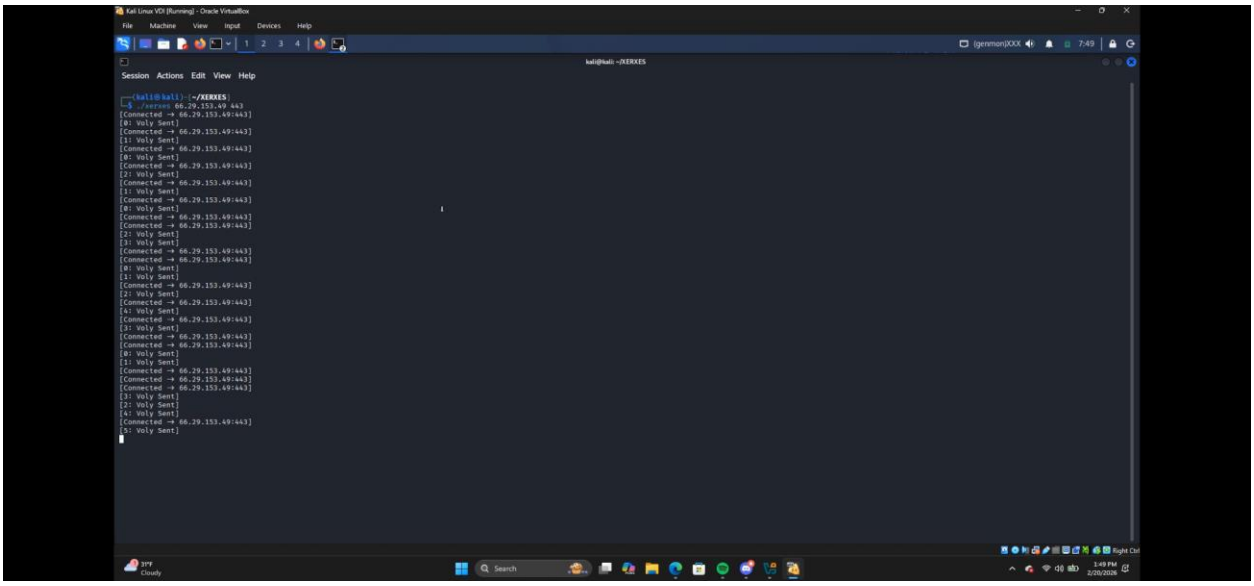
Stage 3: DoS Attack Simulation (Offensive Perspective)

To simulate a denial-of-service scenario, an automated traffic generation tool was used. Manual browser requests would take too long and would not realistically stress the service. The tool was obtained from a public repository hosted on GitHub and executed locally in a controlled lab environment.

The attack involved:

- Specifying the target IP address
- Selecting an active service port
- Initiating repeated automated requests

Once executed, the tool began sending a high volume of traffic to the target service, simulating how availability can be degraded or denied. At this point, the activity represents a DoS attack, because the traffic originates from a single machine.

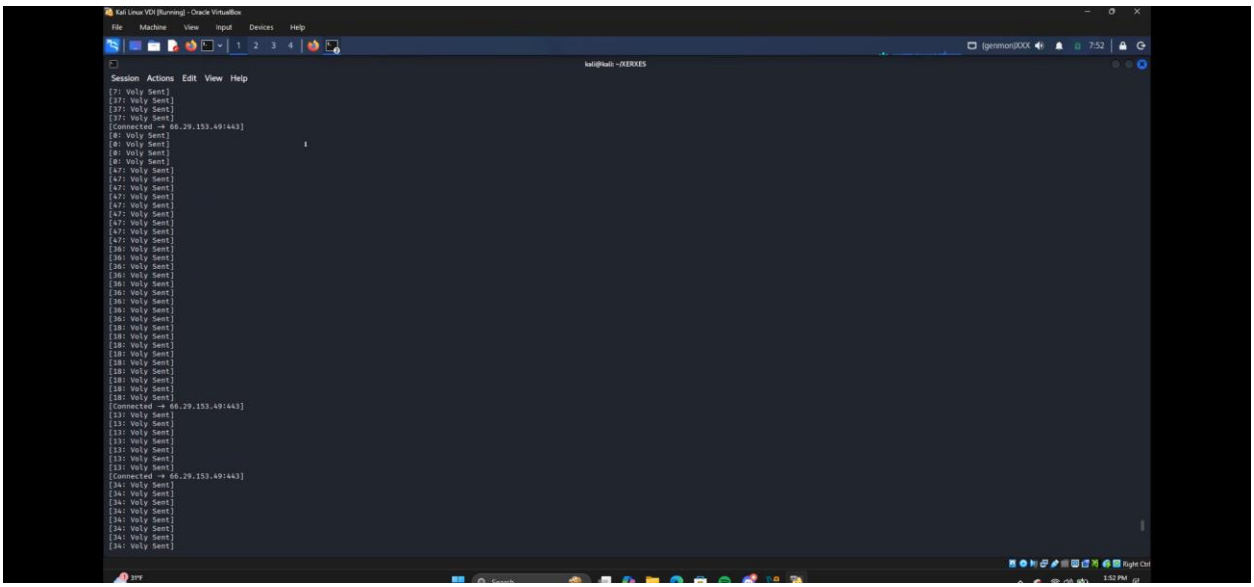


Stage 4: Observing Traffic Behavior and Impact

As traffic increased, the server began responding inconsistently. Instead of processing every request smoothly, the system started:

- Delaying responses
- Dropping requests
- Interrupting sessions

This is a key observation. Even without fully crashing a service, degraded performance already counts as a successful availability attack from a user's perspective.



Stage 5: Transition from DoS to DDoS

While this practical involved one attacking system, the same activity replicated across multiple machines would constitute a Distributed Denial of Service attack.

In real incidents, this distribution often comes from:

- Botnets
- Compromised IoT devices
- Cloud-based attack infrastructure

The key difference is not the technique, but the scale and origin diversity of the traffic.

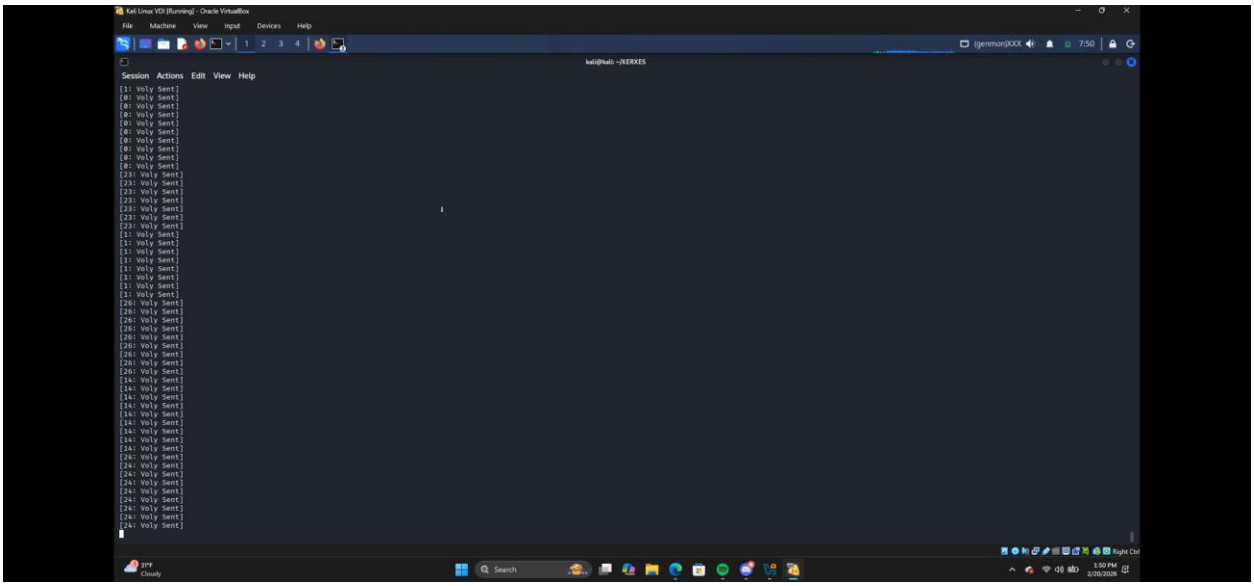
Stage 6: Defensive Detection – Rate Limiting in Action

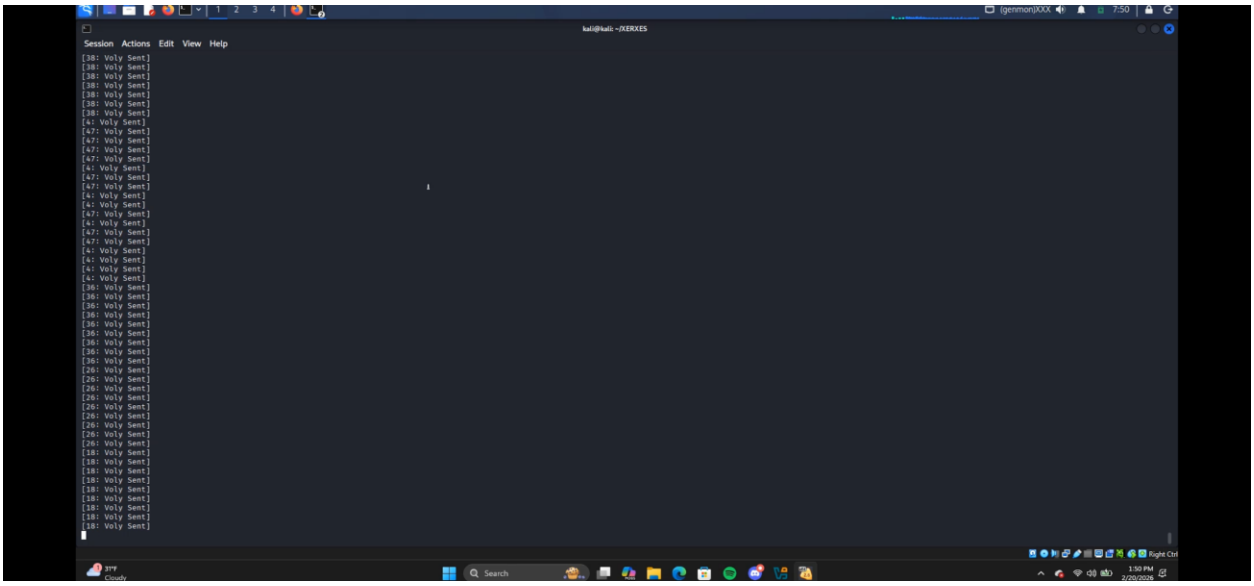
During the attack simulation, important defensive behavior became visible. The server began limiting the number of requests allowed from a single IP address within a given time window. Requests were intermittently blocked, slowed, or reset. This behavior is known as rate limiting, and it is a core defensive mechanism against DoS attacks.

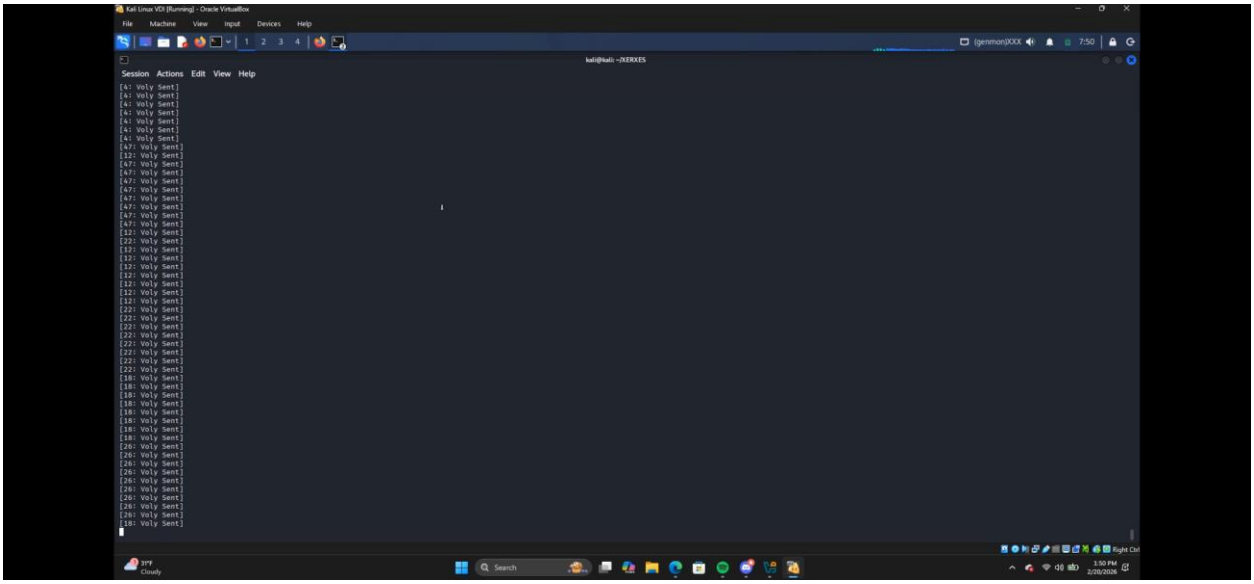
Rate limiting works by:

- Tracking request frequency per IP
- Defining acceptable thresholds
- Temporarily blocking or throttling abusive sources

This confirmed that defensive controls were active.





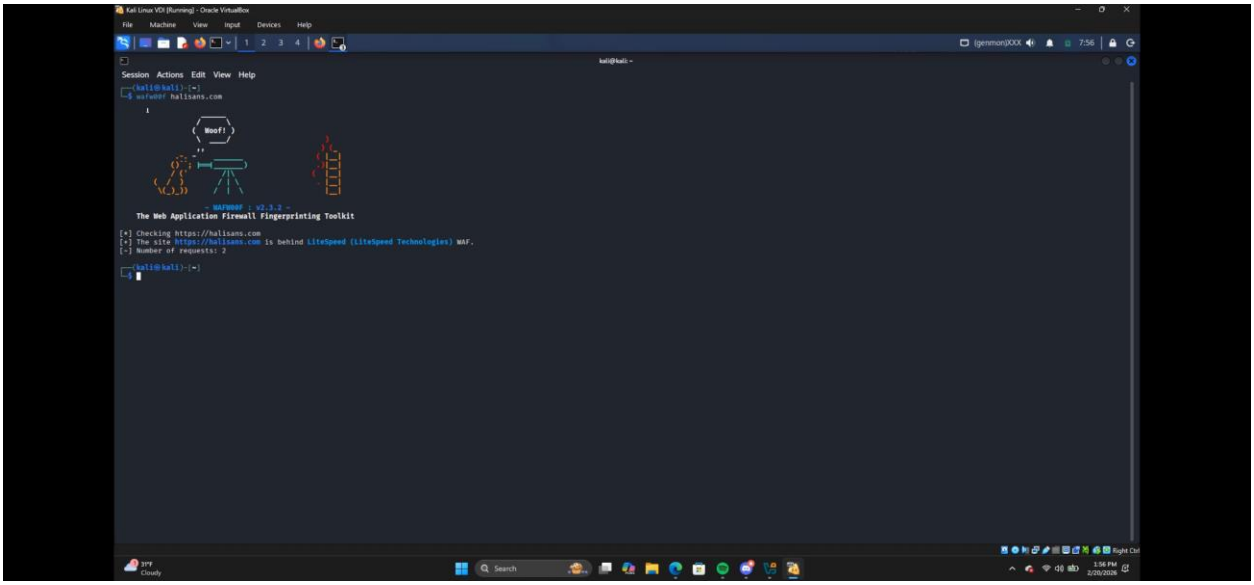


Stage 7: Web Application Firewall (WAF) Presence

Further observation showed that traffic filtering was not random. Patterns indicated the presence of a Web Application Firewall.
A WAF sits in front of the web application and:

- Inspects incoming requests
- Detects abnormal request patterns
- Enforces rules against flooding behavior
- Protects against both volumetric and application-layer attacks

The attack tool's output showed interrupted request sequences, which is a strong indicator that the WAF was actively interfering with malicious traffic.



Stage 8: Organizational Response and Incident Handling

From a defender's perspective, a DDoS incident does not end at detection. A proper response includes:

- Alert generation through monitoring systems
- Traffic analysis using logs and metrics
- IP reputation checks
- Temporary blocking or geo-filtering
- Communication with hosting providers or ISPs if escalation is required

In mature environments, this process is partially automated, but human oversight remains critical, especially during large-scale attacks.

Stage 9: Protection and Long-Term Mitigation Strategies

Based on the observations from this practical, effective DDoS protection includes:

- Properly configured Web Application Firewalls
- Rate limiting tuned to business traffic patterns
- Network-level filtering and firewall rules
- Load balancing and redundancy
- DDoS mitigation services from upstream providers
- Continuous monitoring and log analysis

The key idea is simple but important. You do not stop DDoS attacks by reacting once. You stop them by designing systems that expect abuse and fail gracefully.

Key Skills Demonstrated

This practical demonstrates hands-on capability in:

- Understanding DoS vs DDoS attack mechanics
- Simulating availability attacks in a controlled environment
- Identifying relevant ports and public-facing services
- Observing real-time impact of traffic flooding
- Recognizing rate limiting behavior
- Identifying WAF intervention patterns
- Explaining organizational detection and response workflows
- Translating offensive techniques into defensive improvements

Conclusion

This exercise reinforced a core truth in cybersecurity. Attacks are rarely mysterious. What matters is whether systems are prepared for them. By simulating a denial-of-service attack and observing how defensive mechanisms respond, I demonstrated both offensive awareness and defensive maturity. This dual perspective is essential in real-world security operations, where understanding the attacker’s mindset directly informs stronger defenses.